Patch Sources

untrusted

LLM Patch Generator

· local open-weight model

· isolated process, loopback only

· no repository, no real secrets

Developer Revision

· new version; AI output kept

· same gate, no bypass

1

CredProof Trusted Gate

Policy $\mathcal{P}$

credproof.toml — declared by humans, immutable to the model

entry · mutable scope M · allowed / forbidden dirs · allowed service · credential env · required tests T · scenarios S

Isolation Boundary

bubblewrap · read-only rootfs · private network · empty env · rlimits

Disposable copy
tool ⊕ Δ, required tests T

Canary credential c
fresh random secret per run

Access component
policy-bound read / GET, no redirect

Mock services
allow (/redirect → deny) · deny

2

Observation Layer

installed before project code is imported

O_{file}
audit(open) → canonical path → allow / forbid

O_{net}
connections + service receipts (path, auth)

O_{leak}
c in return · stdout · stderr · log · exception

O_{test}
per-case pytest: collected · run · passed · skipped

3

Verdict Engine

fixed program · 14 predicates over evidence E

Φ_{safe} no leak · no forbidden read · no forbidden service

Φ_{obl} reads allowed file · authenticates to service

Φ_{biz} required tests pass · scenarios as declared

UNKNOWN E incomplete: blocked · skipped · not reached

FAIL $\exists\varphi \in \Phi : \varphi(E) = \bot$

PASS $\forall\varphi \in \Phi : \varphi(E) = \top$

4

Evidence Binding

verdicts and decisions tied to exact bytes

h = H(tree ‖ $\mathcal{P}$ ‖ T ‖ component)

report r applies iff r.h = h

versions v_0 (AI) → v_1 (developer) → …

guarded op ⟨v, h, H(r), |D|⟩ must match

8

PASS only

5

Human Authority & Delivery

Human Approval

· approve only a current PASS

· cannot override FAIL / UNKNOWN

· append-only decisions

6

Evidence Bundle

· Δ, $\mathcal{P}$, tests, component, report

7

Independent Recheck

· fresh environment, full re-run

· never trusts a stored verdict

Regression Test → CI

· re-verifies every commit

data flow · feedback · isolation boundary · untrusted

1 propose Δ · 2 execute T, S in isolation · 3 collect evidence E · 4 verdict V bound to h

5 human approval · 6 export bundle · 7 independent re-execution · 8 counterexample feedback